

MARCO INTEGRATIVO GQM + PRAGMATIC

Metodología de Trazabilidad de Indicadores DORA a Datos Técnicos

Versión: 1.0

Fecha: Enero 2026

Clasificación: Profesional — Marco de Medición Institucional

Aplicabilidad: España, Instituciones Financieras, Regulación DORA

TABLA DE CONTENIDOS

1. Introducción al Marco
2. GQM: Estructura Jerárquica de Medición
3. PRAGMATIC: Criterios de Calidad de Métricas
4. Integración GQM-PRAGMATIC
5. Indicadores DORA Mapeados (Ejemplos Detallados)
6. Trazabilidad Objetivos Nacionales — Datos Técnicos

INTRODUCCIÓN AL MARCO

1.1 Propósito

Este marco proporciona **trazabilidad rigurosa** desde:

- **Nivel 1 (Estratégico):** Objetivos nacionales (DORA compliance España)
- **Nivel 2 (Táctico):** Preguntas operacionales (¿Cómo cumplimos DORA?)
- **Nivel 3 (Técnico):** Métricas cuantitativas específicas (Números reales)
- **Nivel 4 (Calidad):** Evaluación PRAGMATIC de cada métrica

1.2 Motivación Metodológica

Problema típico sin GQM-PRAGMATIC:

"Vamos a medir ciberseguridad."

- Se instala SIEM
- Se generan 500 dashboards
- Nadie entiende qué significa nada
- Dinero gastado sin valor capturado

Solución con GQM-PRAGMATIC:

1. Goal: Detectar incidentes dentro 15 minutos (DORA requirement)
 2. Questions: ¿Qué eventos TIC son críticos? ¿Cuál es umbral de severidad?
 3. Metrics: MTTD = $(\sum \text{tiempo detección} / N \text{ incidentes})$ medido via SIEM
 4. PRAGMATIC: ¿Puede guiar acción? ¿Es predictivo? ¿Está disponible?
- Clarity, actionability, value

GQM: ESTRUCTURA JERÁRQUICA DE MEDICIÓN

2.1 El Modelo de Tres Niveles

Nivel 1 — Conceptual (Goal):

Definición: Objetivo estratégico especificado respecto a:

- OBJETO: ¿Qué medimos? (proceso, producto, recurso)
- PROPÓSITO: ¿Por qué? (mejorar, monitorear, validar)
- PERSPECTIVA: ¿Desde qué vista? (ejecutiva, operacional, técnica)
- CONTEXTO: ¿Bajo qué ambiente? (regulación DORA, sector financiero)

Ejemplo DORA:

OBJETO: Tiempo de detección de incidentes TIC
PROPÓSITO: Cumplir requisito Artículo 18-20 DORA
PERSPECTIVA: CISO + Risk Officer
CONTEXTO: Institución financiera EU regulada

Nivel 2 — Operacional (Questions):

Definición: Preguntas que descomponen goal en elementos medibles

Patrón: "¿Cómo podemos caracterizar el objeto respecto al goal?"

Ejemplos para MTTD Goal:

- Q1: ¿Cuál es el tiempo medio desde ocurrencia hasta detección?
- Q2: ¿Varían tiempos detectados por tipo de incidente?
- Q3: ¿Qué sistemas/logs genera alerts?
- Q4: ¿Cuál es la precisión de detección (false positive rate)?
- Q5: ¿Existe correlación entre MTTD y criticidad del sistema?

Nivel 3 — Cuantitativo (Metrics):

Definición: Métricas específicas que responden cada question

Patrón: Formula + Unidad + Umbral + Frecuencia recolección

Ejemplos para Q1 (MTTD medio):

MÉTRICA: $MTTD = (\Sigma(\text{timestamp detección} - \text{timestamp ocurrencia}) / N \text{ incidentes críticos})$

UNIDAD: Minutos

UMBRAL DORA: <15 minutos

FRECUENCIA: Diario; reporte semanal

FUENTE DATA: SIEM logs + incident tickets

Ejemplos para Q2 (Variación por tipo):

MÉTRICA: MTTD_ransomware, MTTD_phishing, MTTD_intrusion (separados)

UNIDAD: Minutos

ANÁLISIS: Comparación Q-on-Q (trimestral)

2.2 Construcción de GQM Model (Proceso de 11 Pasos)

Fase Planning:

1. Identificar stakeholders (CISO, CRO, Board, reguladores)
2. Definir contexto organizacional (tamaño, modelo, regulación)

Fase Definition:

3. Definir measurement goals (Q. anteriores)

4. Revisar modelos de procesos (NIST CSF, DORA RTS)
5. Conducir GQM interviews (recopilar expert opinions)
6. Definir questions (descomponer goals)
7. Revisar questions por consistencia/completitud
8. Definir metrics (operacionalizar questions)
9. Verificar metrics (no duplicatas, cálculo factible)
10. Producir GQM plan formal
11. Revisar plan (validación)

Fase Data Collection:

12. Implementar colección automatizada (via SIEM, ticketing, etc.)

Fase Interpretation:

13. Analizar data vs. thresholds
14. Generar insights accionables
15. Feedback loop → refinamiento goals/metrics

PRAGMATIC: CRITERIOS DE CALIDAD DE MÉTRICAS

3.1 Los Nueve Criterios PRAGMATIC

Adaptados de literatura de medidas pragmáticas (Glasgow 2013, Stanick 2018, Hull 2022) aplicados a contexto ciberseguridad-financiero:

1. PREDICTIVO (P)

Definición: ¿Predice problemas futuros? ¿Proporciona early warning?

Aplicación DORA:

- MTTD bajo (<15 min) → predice capacidad response rápida → cumpliría SLA 4h notificación
- Vulnerabilities sin parchear (CVSS ≥7) después de 30 días → predice breach probable

Scoring 1-5:

- (1) No hay predictibilidad; métrica reactiva pura
- (3) Predice algunos escenarios; cobertura parcial
- (5) Predice de forma confiable; early warning probado

2. RELEVANTE (R)

Definición: ¿Importa a stakeholders? ¿Alineado con objetivos estratégicos?

Aplicación DORA:

- MTTD <15 min: Relevante para CISO (operacional), CRO (riesgo), Junta (governance)
- Alert fatigue (false positive rate): Relevante para SOC (burnout), CISO (tuning), CFO (ROI)

Scoring 1-5:

- (1) Métrica técnica pura; desconectada de objetivos negocio

- (3) Relevante para algunos stakeholders
- (5) Crítico para ejecutivos, reguladores, y toma decisiones

3. ACCIONABLE (A)

Definición: ¿El resultado guía decisiones/acciones específicas?

Aplicación DORA:

- MTTD 45 min (vs. target 15) → Acción: Implementar SIEM rules, automatizar alertas
- Vendor assessment coverage 72% (vs. target 100%) → Acción: Acelerar due diligence
- Phishing click rate 15% → Acción: Intensificar training específico en departamentos high-risk

Scoring 1-5:

- (1) No hay decisión clara asociada al resultado
- (3) Acciones posibles, pero no prescriptivas
- (5) Métrica directamente vincula a decisiones/acciones específicas

4. GENUINO (G)

Definición: ¿Mide realmente lo que dice? ¿Es válido?

Aplicación DORA:

- MTTD genuino requiere: timestamp exacto ocurrencia (event log), timestamp detección (SIEM alert), sincronización horaria
- Vulnerabilities "parchadas" genuino requiere: verificación que patch fue instalado Y verificado funcionando (no solo "deployed")

Scoring 1-5:

- (1) Métrica mide proxy débil; validity cuestionable
- (3) Validity acceptable con algunas limitaciones conocidas
- (5) Validity fuerte; bien calibrado; correlación probada

5. SIGNIFICATIVO (S)

Definición: ¿La magnitud es interpretable? ¿Contexto claro?

Aplicación DORA:

- MTTD 15 min vs. 20 min: Diferencia significativa (33%)?
- Vendor risk score 72 vs. 74 (escala 0-100): Significativo?

Scoring 1-5:

- (1) Magnitudes arbitrarias; difícil interpretar
- (3) Interpretación posible con contexto
- (5) Magnitud intuitiva; benchmarks claros; diferencias significativas obvias

6. PRECISO (P)

Definición: ¿Exactitud aceptable? ¿Confiabilidad de datos?

Aplicación DORA:

- MTTD medido: ± 2 minutos (acceptable), vs. ± 30 minutos (inacceptable)
- Vulnerability count: Scanning engine debe tener $< 5\%$ false positive rate
- False positive rate: Calculable consistentemente via mismo algoritmo

Scoring 1-5:

- (1) Confiabilidad baja; datos inconsistentes
- (3) Precisión acceptable con advertencias conocidas
- (5) Muy preciso; reproducible; error margins pequeños

7. OPORTUNO (O)

Definición: ¿Reporte frecuencia adecuada? ¿Real-time o delayed?

Aplicación DORA:

- MTTD: Reportado diariamente (cuasi-real-time) → permite correcciones ágiles
- Vendor compliance: Reportado mensualmente (vs. anualment) → governance más frecuente
- Board KPIs: Reportados trimestralmente → decisiones timely

Scoring 1-5:

- (1) Información atrasada (trimestral+ delayed); no actionable real-time
- (3) Frecuencia bi-mensual; acceptable para algunos usos
- (5) Disponibilidad real-time o daily; permite decisiones ágiles

8. INDEPENDIENTE (I)

Definición: ¿Gaming-resistant? ¿Difícil de manipular?

Aplicación DORA:

- MTTD: Si SIEM timestamps provienen de reloj sincronizado (NTP), difícil manipular
- Vulnerabilities patched: Si verificación es automática (scanning repeat), gaming difícil
- Alert fatigue: Si calculado via logs auditable (immutable), no manipulable

Scoring 1-5:

- (1) Fácil manipular; basado en auto-report
- (3) Gaming posible pero detectado; controles parciales
- (5) Difícil manipular; transparencia técnica; auditable

9. RENTABLE (R)

Definición: ¿Cost-benefit positivo? ¿Sustainable?

Aplicación DORA:

- SIEM para MTTD: Costo €50K setup + €20K/año → ROI si previene 1 breach medio (€500K+)
- Vendor KPI dashboard: Costo €100K → ROI si reduce vendor risks 30%+
- Board reporting: Costo €5K/mes (analyst) → ROI si mejora decisiones governance

Scoring 1-5:

- (1) Costo prohibitivo; no sostenible
- (3) Cost-benefit borderline; requiere justificación
- (5) Claro positivo ROI; sostenible indefinidamente

3.2 Matriz de Scoring PRAGMATIC

Criterio Alto	Peso Típico	Descriptor Bajo	Descriptor Medio	Descriptor
Predictivo	15%	Reactivo puro	Algunos casos	Early
warning proven				
Relevante	20%	Technical debt	Algunos stakeholders	Crítico
ejecutivos				
Accionable	20%	No decisión clara	Acciones posibles	Guía
directa acciones				
Genuino	15%	Validity débil	Acceptable limitaciones	Validity
fuerte				
Significativo	10%	Arbitrario	Interpretable	Intuitivo
Preciso	10%	Inconsistente	±5-10% error	±<2% error
Oportuno	15%	Atrasado (trimestral)	Bi-mensual	Real-
time/daily				
Independiente	10%	Gaming fácil	Gaming difícil	
Inmutable/auditable				
Rentable	15%	Prohibitivo	Borderline	ROI claro

Cálculo Score PRAGMATIC de métrica:

$$\text{Score_PRAGMATIC} = \Sigma(\text{Puntuación_criterio} \times \text{Peso}) / 100$$

Rango: 1.0 - 5.0

Interpretación:

- 1.0-2.0: Métrica débil; no recomendada
- 2.0-3.0: Métrica aceptable con limitaciones
- 3.0-4.0: Métrica buena; implementable
- 4.0-5.0: Métrica excelente; recomendada

INTEGRACIÓN GQM-PRAGMATIC

4.1 Flujo de Integración

PASO 1: Definir GOAL (GQM Nivel 1)

↓ Ejemplo: "Detectar incidentes TIC dentro 15 minutos"

PASO 2: Formular QUESTIONS (GQM Nivel 2)

↓ Ejemplo: "¿Cuál es MTTD promedio?" "¿Varían por tipo?"

PASO 3: Especificar METRICS (GQM Nivel 3)

↓ Ejemplo: $MTTD = (\sum \text{tiempos} / N)$; Unidad: minutos

PASO 4: Evaluar PRAGMATIC (Criterios 1-9)

↓ Aplicar scoring 1-5 a cada criterio

↓ Calcular Score_PRAGMATIC ponderado

PASO 5: Decisión Implementación

IF Score_PRAGMATIC $\geq$ 3.5:

→ Métrica recomendada; implementar

IF Score_PRAGMATIC 2.5-3.5:

→ Métrica aceptable con mitigaciones; revisar frecuencia

IF Score_PRAGMATIC $<$ 2.5:

→ Métrica débil; reemplazar con alternativa

4.2 Matriz de Trazabilidad GQM-PRAGMATIC

Indicador: MTTD (Mean Time To Detect)
NIVEL 1 - GOAL (Conceptual)
Objetivo: Detectar incidentes TIC críticos dentro 15 min Propósito: Cumplir DORA Art. 18-20; minimizar dwell time Contexto: Institución financiera EU; SOC 24/7 operando
NIVEL 2 - QUESTIONS (Operational)
Q1: ¿Cuál es tiempo medio detección? Q2: ¿Distribución por tipo incidente? (ransomware/phishing) Q3: ¿Precisión detección? (false positive rate) Q4: ¿Correlación con criticidad? (production vs dev)
NIVEL 3 - METRICS (Quantitative)
M1: $MTTD = (\sum (DetectionTS - OccurrenceTS) / N_{críticos})$ Unidad: Minutos Threshold: <15 min Freq: Diaria M2: MTTD_ransomware, MTTD_phishing (disaggregated) M3: $False_Positive_Rate = (FP_alerts / Total_alerts) \times 100\%$ M4: MTTD_Production vs MTTD_Development (separately tracked)
NIVEL 4 - PRAGMATIC Evaluation
Predictivo: $(4/5) \times 15\% = 0.60 \rightarrow$ Predice response speed Relevante: $(5/5) \times 20\% = 1.00 \rightarrow$ Critical para CISO/CRO Accionable: $(5/5) \times 20\% = 1.00 \rightarrow$ Guía tuning SIEM Genuino: $(4/5) \times 15\% = 0.60 \rightarrow$ Válido con sync check Significativo: $(5/5) \times 10\% = 0.50 \rightarrow$ 15 vs 45 min claro Preciso: $(5/5) \times 10\% = 0.50 \rightarrow \pm 1$ min error Oportuno: $(5/5) \times 15\% = 0.75 \rightarrow$ Real-time alertas Independiente: $(4/5) \times 10\% = 0.40 \rightarrow$ NTP timestamp dif. Rentable: $(4/5) \times 15\% = 0.60 \rightarrow$ SIEM ROI claro
SCORE_PRAGMATIC = $4.95 / 5.0 = 4.95 / 100 = 0.99 = 4.95 (?)$ [Cálculo corrected: $(0.60+1.00+1.00+0.60+0.50+0.50+0.75+0.4+0.60)/9 = 6.95/9 = 0.772 \rightarrow 3.86/5]$
RECOMENDACIÓN: ✓ Métrica EXCELENTE; implementar

INDICADORES DORA MAPEADOS (EJEMPLOS DETALLADOS)

5.1 Indicador 1: MTTD <15 Minutos (Artículo 18 DORA)

GQM Structure:

Goal:	Detectar 95% incidentes críticos dentro 15 minutos
Questions:	Q1: ¿Cuál es MTTD actual? Q2: ¿Qué eventos se detectan rápido vs lento? Q3: ¿Es MTTD predictivo de MTTR?
Metrics:	MTTD, MTTD by incident type, MTTD vs MTTR correlation

PRAGMATIC Evaluation:

Criterio	Score	Justificación
Predictivo	4	Bajo MTDD predice MTTR bajo (correlación 0.82)
Relevante	5	Crítico para cumplimiento DORA + operacional
Accionable	5	Guía inversión SIEM, rules tuning, automation
Genuino	4	Válido si timestamps sincronizados NTP
Significativo	5	15 vs 45 min es diferencia operacional clara
Preciso	5	Precisión ± 1 minuto via SIEM logs
Oportuno	5	Reporte diario; dashboards real-time
Independiente	4	Gaming difícil; basado en logs inmutables
Rentable	4	SIEM ROI >150% si previene breach

Score PRAGMATIC Ponderado: 4.33/5.0 – EXCELENTE

5.2 Indicador 2: Vendor Risk Assessment Coverage (Artículo 28 DORA)

GQM Structure:

Goal:	100% de proveedores críticos evaluados formalmente anualmente
Questions:	Q1: ¿% proveedores completaron due diligence? Q2: ¿Contratos incluyen cláusulas DORA? Q3: ¿Monitoreo post-contrato es continuo?
Metrics:	Coverage %, DORA-compliance contract rate, monitoring frequency

PRAGMATIC Evaluation:

Criterio	Score	Justificación
Predictivo	3	Predice algunos riesgos; no siempre temprano
Relevante	5	Crítico para gestión riesgos terceros
Accionable	5	Guía priorización due diligence
Genuino	3	Válido pero depende de cuestionarios conforme
Significativo	5	Diferencia 72% vs 100% es claramente material
Preciso	3	Precisión afectada por subjetividad scoring
Oportuno	4	Reporte trimestral; aceptable
Independiente	3	Gaming posible (evaluadores sesgados)
Rentable	4	Inversión moderada; ROI > 100%

Score PRAGMATIC Ponderado: 3.78/5.0 – BUENO

5.3 Indicador 3: Vulnerabilities Patched Within SLA (Artículo 24 DORA)

GQM Structure:

Goal: 100% vulnerabilities CVSS ≥ 7.0 parchadas dentro 30 días

Questions: Q1: ¿% vulns CVSS ≥ 7 parchadas in time?

Q2: ¿Cuál es MTTR por severidad?

Q3: ¿Correlación con breach rate?

Metrics: Patch_rate %, MTTR by CVSS tier, breach prevention

PRAGMATIC Evaluation:

| Criterio | Score | Justificación |

|-----|-----|-----|

| Predictivo | 5 | Alto CVSS sin patch – breach muy probable |

| Relevante | 5 | Crítico para postura defensiva |

| Accionable | 5 | Guía priorización patch management |

| Genuino | 5 | Válido; verificable automáticamente |

| Significativo | 5 | Diferencia 90% vs 100% es material |

| Preciso | 5 | Precisión alta; scanners fiables |

| Oportuno | 5 | Real-time tracking; diario reporte |

| Independiente | 5 | Difícil manipular; scanning repeat |

| Rentable | 5 | Costo patches << Costo breach |

Score PRAGMATIC Ponderado: 4.78/5.0 – EXCELENTE

TRAZABILIDAD NACIONAL: OBJETIVOS ESPAÑA → DATOS TÉCNICOS

6.1 Cadena de Trazabilidad Jerárquica

NIVEL 0 – OBJETIVO NACIONAL (Regulación Española)

"Cumplimiento DORA en Instituciones Financieras Españolas"
Autoridades: Banco de España, CNMV, INCIBE
Horizonte: Enero 2025 - Auditoría Supervisora Q2-Q3 2026



NIVEL 1 – OBJETIVO INSTITUCIONAL (Por Entidad Financiera)

Institución: Banco/Aseguradora Española
Objetivo: Alcanzar CMI ≥ 3.5 (Managed) en DORA compliance
Responsable: CRO + CISO
Presupuesto: €1.5M - €3M (2025-2026)



NIVEL 2 – OBJETIVOS TÁCTICOS (Por Pilar DORA)

Pilar 1: Gestión Riesgos TIC
Objetivo: Evaluación anual formal; FAIR implementation
Target: GAP coverage $\geq 90\%$

Pilar 2: Gestión Incidentes
Objetivo: MTTD < 15 min; notificación 4h/72h/30d compliant
Target: 100% incidentes clasificados correctamente

Pilar 3: Testing Resiliencia
Objetivo: TLPT bienal para significativas
Target: Vulnerabilidades críticas < 5

Pilar 4: Gestión Terceros
Objetivo: 100% critical vendors evaluated + monitored
Target: DORA-compliant contracts 100%

Pilar 5: Capacitación
Objetivo: 100% staff training + monthly phishing sims
Target: Click rate $< 8\%$



NIVEL 3 – OBJETIVOS OPERACIONALES (GQM Goals)

GOAL 1: Detectar 95%+ incidentes críticos dentro 15 min
GOAL 2: Remediación incidentes críticos < 4 h
GOAL 3: Vulnerabilidades CVSS ≥ 7 parchadas ≤ 30 días
GOAL 4: 100% proveedores críticos con evaluation formal
GOAL 5: Incident notification autoridades ≤ 4 h (inicial)
GOAL 6: DR/BCP testing semestral; RTO cumplido
GOAL 7: 100% personal capacitado DORA requirements
GOAL 8: Junta Directiva reportes trimestrales DORA compliance
... (32+ goals total mapeados a DORA RTS)



NIVEL 4 – PREGUNTAS OPERACIONALES (GQM Questions)

Para GOAL 1 (MTTD):
Q1.1: ¿Cuál es tiempo medio detección actual?
Q1.2: ¿Varianza por tipo incidente?
Q1.3: ¿Precisión detección (false positives)?
Q1.4: ¿Correlación MTTD vs MTTR?
Para GOAL 2 (MTTR):
Q2.1: ¿Cuál es time medio remediación?

Q2.2: ¿SLA cumplimiento rate?
Q2.3: ¿Varianza por severidad?
... (100+ questions total)



NIVEL 5 – MÉTRICAS CUANTITATIVAS (GQM Metrics)

M1.1: $MTTD = (\sum \text{tiempos detección} / N \text{ incidentes críticos})$
Fuente: SIEM logs | Unidad: Minutos | Freq: Diaria

M1.2: MTTD_ransomware, MTTD_phishing, MTTD_intrusion (sep.)
Fuente: Incident tickets | Unidad: Minutos

M1.3: $False_Positive_Rate = (\text{Falsos_Alerts} / \text{Total_Alerts}) \times 100\%$
Fuente: SIEM tuning history | Unidad: %

M1.4: $CORR(MTTD, MTTR) = \text{Pearson correlation coefficient}$
Fuente: Incident database | Valor: -1 to +1

M2.1: $MTTR = (\sum \text{tiempos remediación} / N \text{ incidentes})$
Fuente: Incident tickets | Unidad: Horas

M2.2: $SLA_Compliance = (\text{Incidentes remediados } \leq 4h / \text{Total}) \times 100\%$
Fuente: Incident management system

M3.1: $Patch_Rate = (\text{Vulns CVSS} \geq 7 \text{ parchadas } \leq 30d / \text{Total}) \times 100\%$
Fuente: Vulnerability scanner + patch tracking

M4.1: $Vendor_Coverage = (\text{Vendors evaluated} / \text{Total críticos}) \times 100\%$
Fuente: TPRM platform | Unidad: %

M5.1: $Training_Completion = (\text{Staff completados} / \text{Total}) \times 100\%$
Fuente: LMS logs | Unidad: %

M5.2: $Phishing_Click_Rate = (\text{Clicks phishing sim} / \text{Total mails}) \times 100\%$
Fuente: Phishing simulation platform

... (80+ métricas técnicas específicas)



NIVEL 6 – EVALUACIÓN PRAGMATIC (Quality Assessment)

Para cada métrica (M1.1, M1.2, ... M5.2):
Score cada criterio PRAGMATIC (1-5)
Calcular Score_PRAGMATIC_ponderado
Decisión: Implementar si $Score \geq 3.5$

Matriz consolidada: 80+ métricas × 9 criterios = Matriz 80×9



NIVEL 7 – IMPLEMENTACIÓN TÉCNICA (Data Infrastructure)

Herramientas: SIEM (Splunk/ELK), Vulnerability scanners
Incident management system, TPRM platform
Phishing simulation, LMS

Pipelines: SIEM logs → Parsers → Storage → Analytics → Reports
Scans → Scoring → Dashboards → Alerts → Escalation

Frecuencia: Real-time → Daily → Weekly → Monthly → Quarterly

(Depends on metric type)

↓

NIVEL 8 – SUPERVISIÓN Y AJUSTE CONTINUO (Governance Feedback Loop)

Reporte CISO a CRO (mensual): MTTD trending, gaps identified
Reporte CRO a Junta (trimestral): CMI score, roadmap progress
Auditoría supervisora (Q2-Q3 2026): Validación cumplimiento

Feedback: Si métrica no alineada → Refinement → Retorno Nivel 3
Si implementación insuficiente → Roadmap aceleramiento
Si regulatory guidance cambia → Revisión Level 2-3

6.2 Mapeo Explícito: España → Datos Técnicos (Ejemplo Completo)

OBJECTIVE NACIONAL

"Cumplimiento DORA en Sector Financiero Español"

Responsable: Banco de España + CNMV

Deadline: Auditoría supervisora Q2 2026

↓ (desagrega)

OBJETIVO INSTITUCIÓN

"Banco Regional Español, Asset €2B"

Objetivo: CMI ≥ 3.5 ; auditoría supervisora aprobada

Responsable: CRO + CISO

↓ (desagrega)

OBJETIVO PILAR DORA

"Pillar 2: Gestión de Incidentes TIC (Article 18-20)"

Objetivo: Notificación autoridades $\leq 4h$; MTTD $< 15min$

Responsable: CISO

↓ (desagrega)

GQM GOAL

"Detectar 95%+ incidentes TIC críticos dentro 15 minutos"

Propósito: Habilitar compliance con Artículo 18 DORA

Stakeholders: CISO, CRO, SOC team

↓ (desagrega)

GQM QUESTIONS

Q1: ¿Cuál es tiempo medio detección (MTTD) actual?

Q2: ¿Varía MTTD por tipo incidente? (ransomware vs intrusion)

Q3: ¿Cuál es precisión detección? (false positive rate)

Q4: ¿Detectamos 95%+ incidentes críticos? (coverage)

Q5: ¿Existe correlación MTTD vs severity? (escalation patterns)

↓ (operacionaliza)

GQM METRICS

M1: MTTD (promedio)

$$= (\sum (\text{DetectionTime} - \text{OccurrenceTime}) / N_{\text{critical_incidents}})$$

Fuente de datos: SIEM logs (e.g., Splunk)

Unidad: Minutos

Umbral: < 15 minutos (DORA target)

Frecuencia colección: Real-time; agregación diaria

M2: MTTD por tipo incidente

$$\text{MTTD}_{\text{ransomware}} = (\sum \text{tiempos ransomware} / N_{\text{ransomware}})$$

$$\text{MTTD}_{\text{phishing}} = (\sum \text{tiempos phishing} / N_{\text{phishing}})$$

$$\text{MTTD}_{\text{intrusion}} = (\sum \text{tiempos intrusion} / N_{\text{intrusion}})$$

Fuente: Incident management system (e.g., Jira Service Management)

M3: False Positive Rate

$$= (\text{Número alertas falsas} / \text{Total alertas}) \times 100\%$$

Fuente: SIEM tuning logs + manual validation

Unidad: %

Umbral: <10% (industria best practice)

M4: Detection Coverage

= (Incidentes críticos detectados / Total críticos ocurridos) × 100%

Fuente: Correlación SIEM detections + post-mortems

Umbral: >95%

M5: MTTD vs Severity Correlation

= CORR(MTTD, IncidentSeverity)

Fuente: Pearson correlation via analytics engine

Esperado: Correlación negativa (higher severity → faster detection)

↓ (implementa técnicamente)

INFRAESTRUCTURA TÉCNICA

SIEM: Splunk Enterprise

- Event ingestion: 50,000 EPS (events per second)
- Data sources: Firewalls, IDS, servers, cloud, applications
- Alert rules: 200+ configured rules (NIST CSF aligned)
- Example rule: "Crypto miner detected" → Alert in <30 sec

Incident Management: Jira Service Management

- Ticket creation: Automated via SIEM webhook
- Fields: incident_id, detection_time, occurrence_time, severity, type
- SLA tracking: <15 min detection target visible in dashboard

Analytics Engine: Custom Python (Pandas, NumPy)

- Daily job (03:00 UTC): Aggregates MTTD metrics
- Calculates M1-M5 metrics
- Outputs to CSV + publishes to BI tool

BI Tool: Tableau

- Dashboard "DORA Incident Management"
- Real-time MTTD gauge; historical trending
- Alert if MTTD > 20 min (early warning)

↓ (monitorea continuamente)

MONITOREO Y REPORTE

Diario:

- Dashboard check: MTTD vs target; alert fatigue rate

Semanal:

- CISO review: Anomalías, incidents con MTTD >15min

Mensual:

- Reporte CRO: Trending M1-M5; SLA performance; gaps
- Governance: Board-level metrics (if in Top 3 KPIs)

Trimestral:

- Autoevaluación DORA: ¿Cumplimos Art. 18? Evidence de MTTD?
- Supervisory readiness: Preparación para auditoria Q2 2026

↓ (feedback loop)

AJUSTE CONTINUO

Si MTTD > 15min (trending):

- Action 1: Increase SOC staffing
- Action 2: Tune SIEM rules (reduce false positives → analyst focus)
- Action 3: Upgrade alerting (from manual to automated)
- Target: MTTD <12 min en 30 días

Si False Positive Rate > 10%:

- Action 1: SIEM tuning sprint (rules review)
- Action 2: Machine learning baseline (behavioral analytics)
- Target: FPR <5% en 60 días

Si Detection Coverage < 95%:

- Action 1: Gap analysis post-mortems (¿qué no detectamos?)
- Action 2: New rule development basado en CAPEC/MITRE ATT&CK
- Target: Coverage >97% en 90 días

CONCLUSIÓN: TRAZABILIDAD END-TO-END

Este marco asegura que:

7. Objetivo Nacional (Cumplimiento DORA España) se desagrega a
8. Objetivos Institucionales (CMI targets) que se descomponen en
9. Objetivos Tácticos (Por pilar DORA) que especifican
10. GQM Goals + Questions que operacionaliza
11. Métricas Cuantitativas que se implementan via
12. Infraestructura Técnica que se monitorea via
13. Reporting Governance que alimenta
14. Ajuste Continuo que refina ciclos de mejora

Cada métrica puede trazarse directamente desde:

- Artículo DORA específico – Goal operacional – Question descomposición – Métrica técnica – Dashboard – Decisión de negocio

Fin del Marco

Enero 2026 — Metodología de Trazabilidad Integral para Resiliencia Digital Española